Breaking TrustZone isolation on AMD Zynq UltraScale+ MPSoC

Proof-of-Concept for CVE-2025-48507 & CVE-2025-0038

I. Breaking TrustZone isolation (CVE-2025-48507)

II. Breaking XPPU/XMPU isolation (CVE-2025-0038)

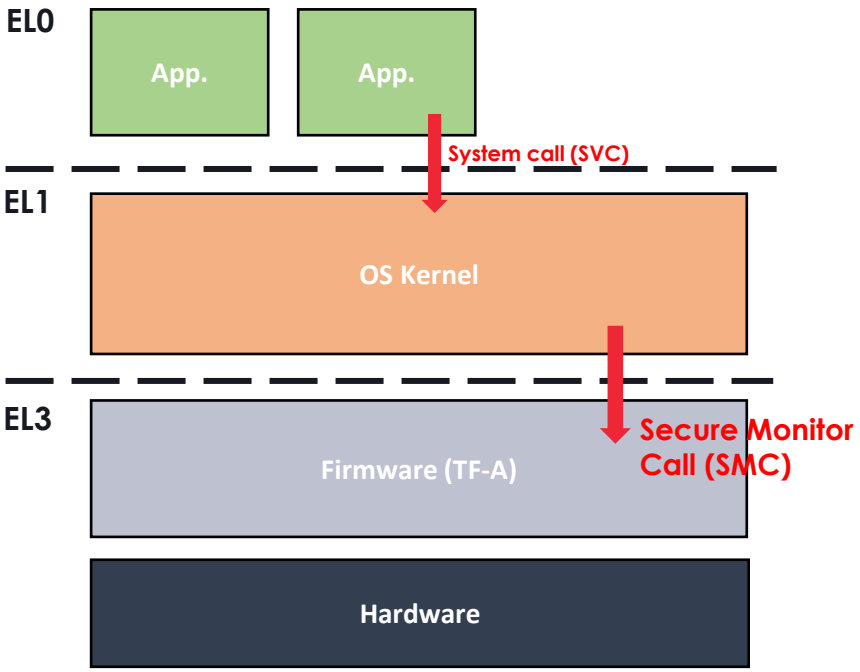
III. Exploit to gain full access to TrustZone's Secure world

Jean de Bonfils Lavernelle - PhD. Thesis: Software Isolation and Virtualization in Embedded Systems: Study of Threats and Protections

What is a Secure Monitor Call?

On ARM's Application processor (Cortex-A)

- The firmware (TF-A) provides services to the OS kernel through the SMC interface
- Allows to access critical functions:
  - crypto, secure services, power management, clock management…



The SMC instruction allows issuing a Secure Monitor Call (SMC)

- X0 : ID of a sub-interface + Function number
- X1-X3: Parameters

The interface is defined in the ARM's SMCCC

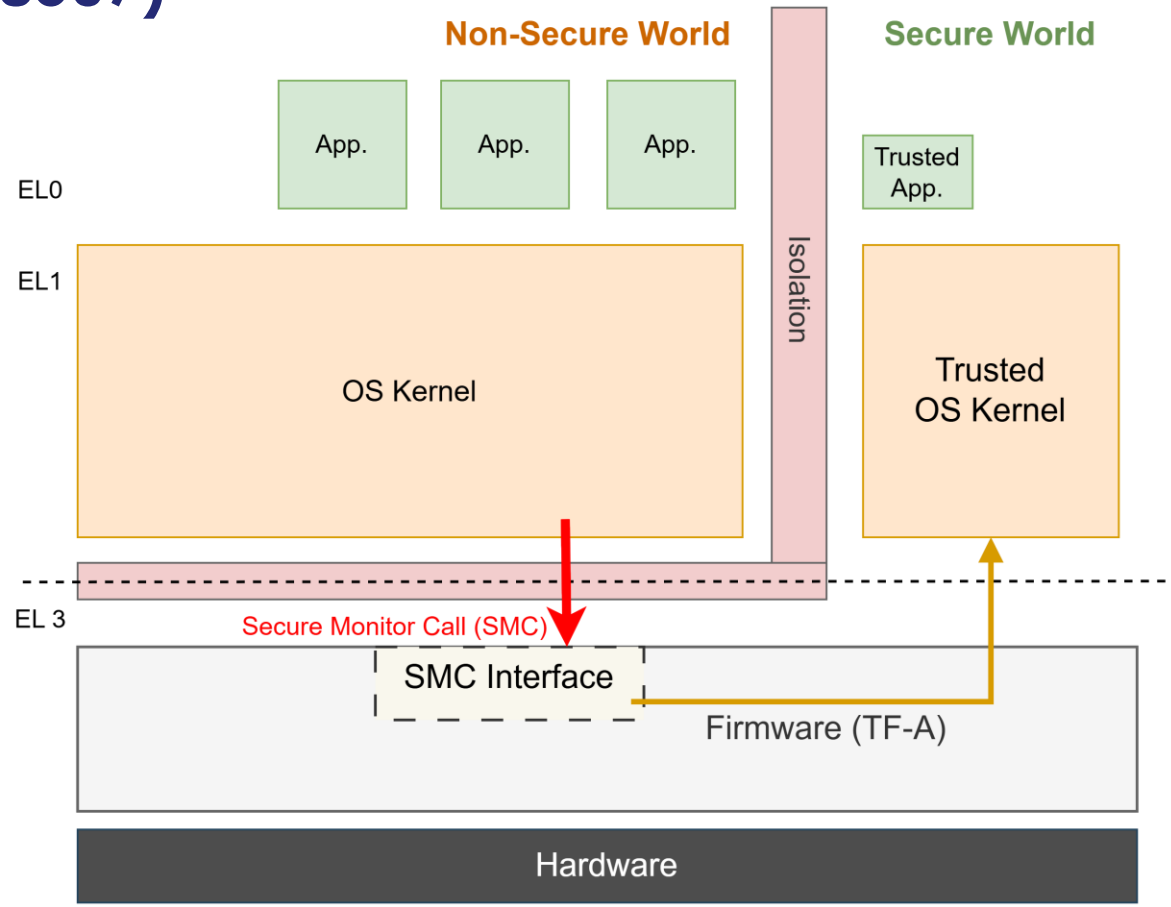
- Some sub-interfaces are generic to ARM, and others are specific.

Type	OEN	Service
Fast	0	Arm Architecture calls
Fast	1	CPU Service calls
Fast	2	SiP Service calls
Fast	3	OEM Service calls
Fast	4	Standard Secure Service calls
Fast	5	Standard Hypervisor Service Calls
Fast	6	Vendor Specific Hypervisor Service Calls
Fast	7	Vendor Specific EL3 Monitor Calls
Fast	8-47	Reserved for future use
Fast	48-49	Trusted Application calls
Fast	50-63	Trusted OS calls

Breaking TrustZone isolation (CVE-2025-48507)

> What is TrustZone?

- Allows creating a Trusted Execution Environment on ARM platforms
- Master can be Secure or Non-Secure
  - E.g., processor, coprocessors, DMA-capable peripherals…
- Slaves can be Secure or Non-Secure
  - E.g., coprocessors, peripherals, memory



ARM Cortex-A CPU

> Secure masters can access Secure and Non-Secure resources

> Non-Secure masters can only access Non-secure slaves

Breaking TrustZone isolation (CVE-2025-48507)

> The Programmable Logic (PL) is a configurable hardware resource (FPGA fabric)

- Provides block RAMs, gates, clock structures, and I/O devices
- From the APU, SMCs can be used to load and save PL bitstreams and configurations

> The SMC: PM_FPGA_READ

- Enables non-secure software to perform a PL configuration read back to memory RAM
- The SMC takes as an argument a memory pointer to which the PL bitstream or configuration must be written back
  - r0: 0xC200002E (SMC PM_FPGA_READ)
  - r1: 0xFF240000 (memory pointer)

- The firmware (TF-A) handles the SMC and forwards the request to a coprocessor through an IPI

Breaking TrustZone isolation (CVE-2025-48507)

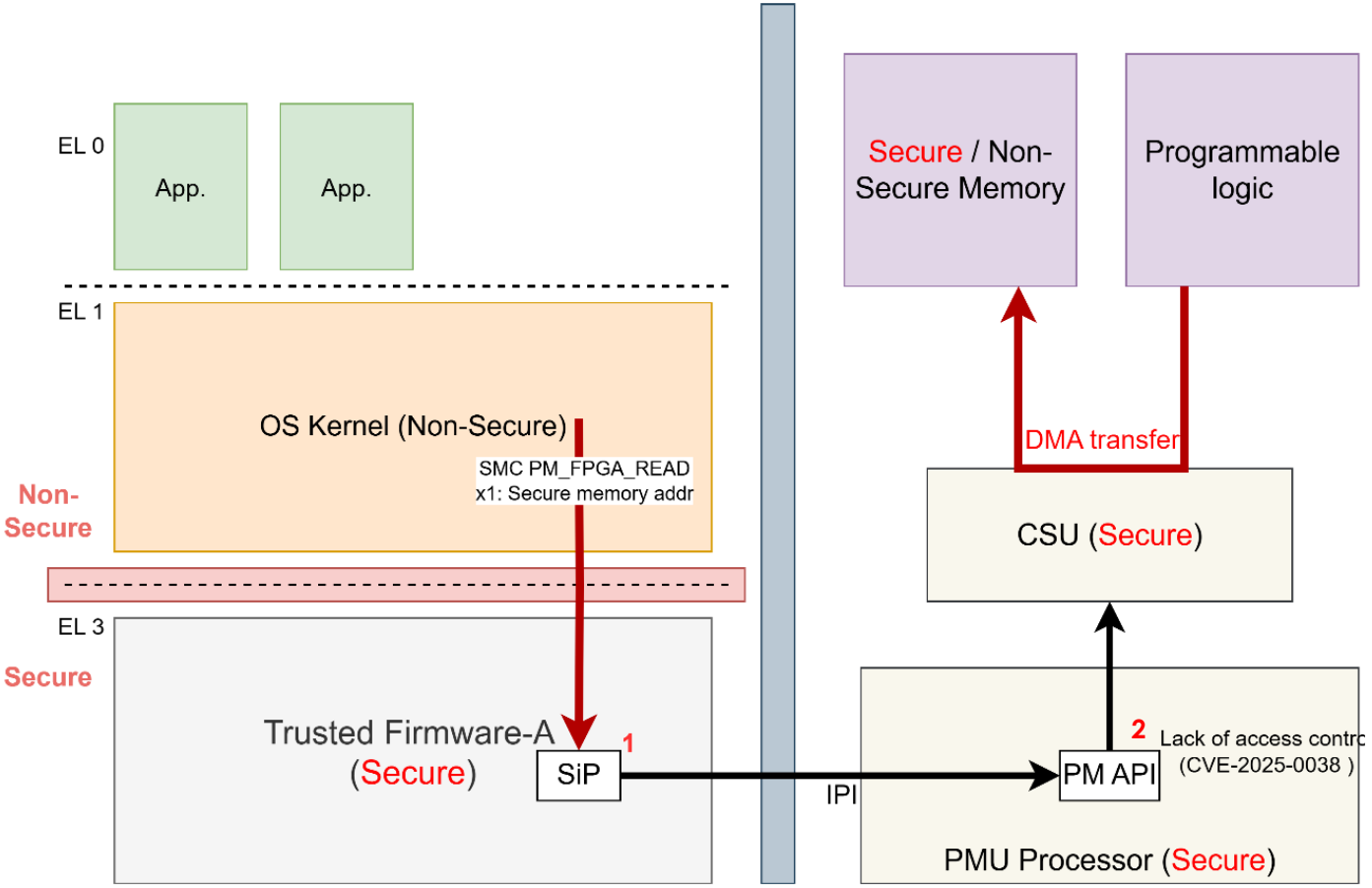
> PM_FPGA_READ execution flow:

1. Non-Secure software issues a SMC to TF-A (Secure)

2. TF-A forwards the request to the PMU via an Inter-Processor Interrupt (IPI)

3. The PMU leverages the CSU runtime Services to execute the request

4. The CSU DMA executes the request and transfers data from the PL to the target memory



> Lack of access control at different levels of granularity

- At TF-A and PMU levels

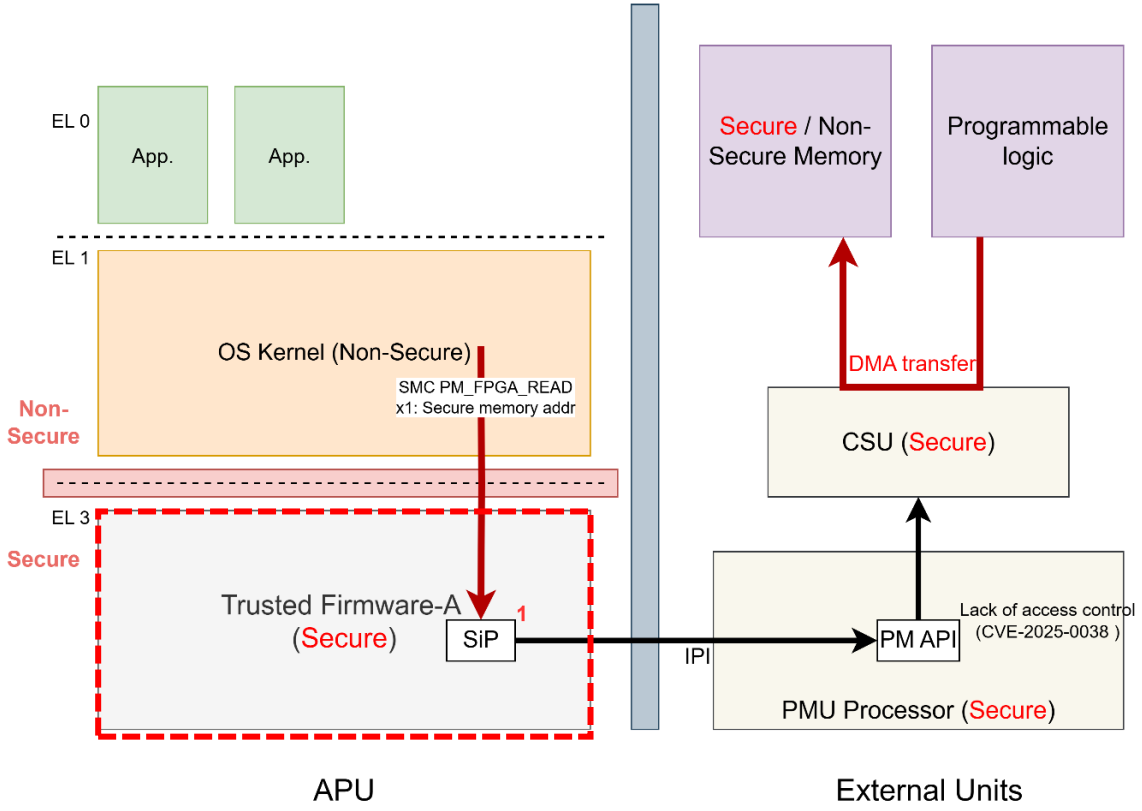
1 CVE-2025-48507

2 CVE-2025-0038

Breaking TrustZone isolation (CVE-2025-48507)

> At firmware level (TF-A):

- The SMC is issued by Non-Secure software
- The SMC is handled by the firmware (TF-A) in **Secure** mode
- No check of the memory pointer passed as an argument to the SMC
- The firmware forwards the request to the PMU via an IPI



> Non-Secure software could issue a SMC PM_FPGA_READ with a memory pointer to Secure memory

- Ultimately, the function is executed by a Secure master
- This enables Non-Secure software to clear arbitrary Secure memory regions

Breaking TrustZone isolation (CVE-2025-48507)

> CVE-2025-48507: Missing Use of the Secure Flag in ZynqTM UltraScale+TM SoC Arm Trusted Firmware

- Description:
  - The security state of the calling processor into Arm® Trusted Firmware (TF-A) is not used and could potentially allow non-secure processors access to secure memories, access to crypto operations, and the ability to turn on and off subsystems within the SOC.

- Severity: **8.6 (High)**
  - CVSS:4.0/AV:L/AC:L/AT:N/PR:L/UI:P/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H

- Affected software:
  - Arm Trusted Firmware for Cortex-A processors (TF-A) and PMU Firmware versions up through 2025.1.
- Affected Devices:
  - Kria SOM, Zynq UltraScale+ MPSoCs, Zynq UltraScale+ RFSoC

- Remediation:
  - Namely, the Arm Cortex-A processor's security state information – secure or non-secure – will be passed from Arm Trusted Firmware to the PMU firmware in order to decide whether or not an operation will be allowed.

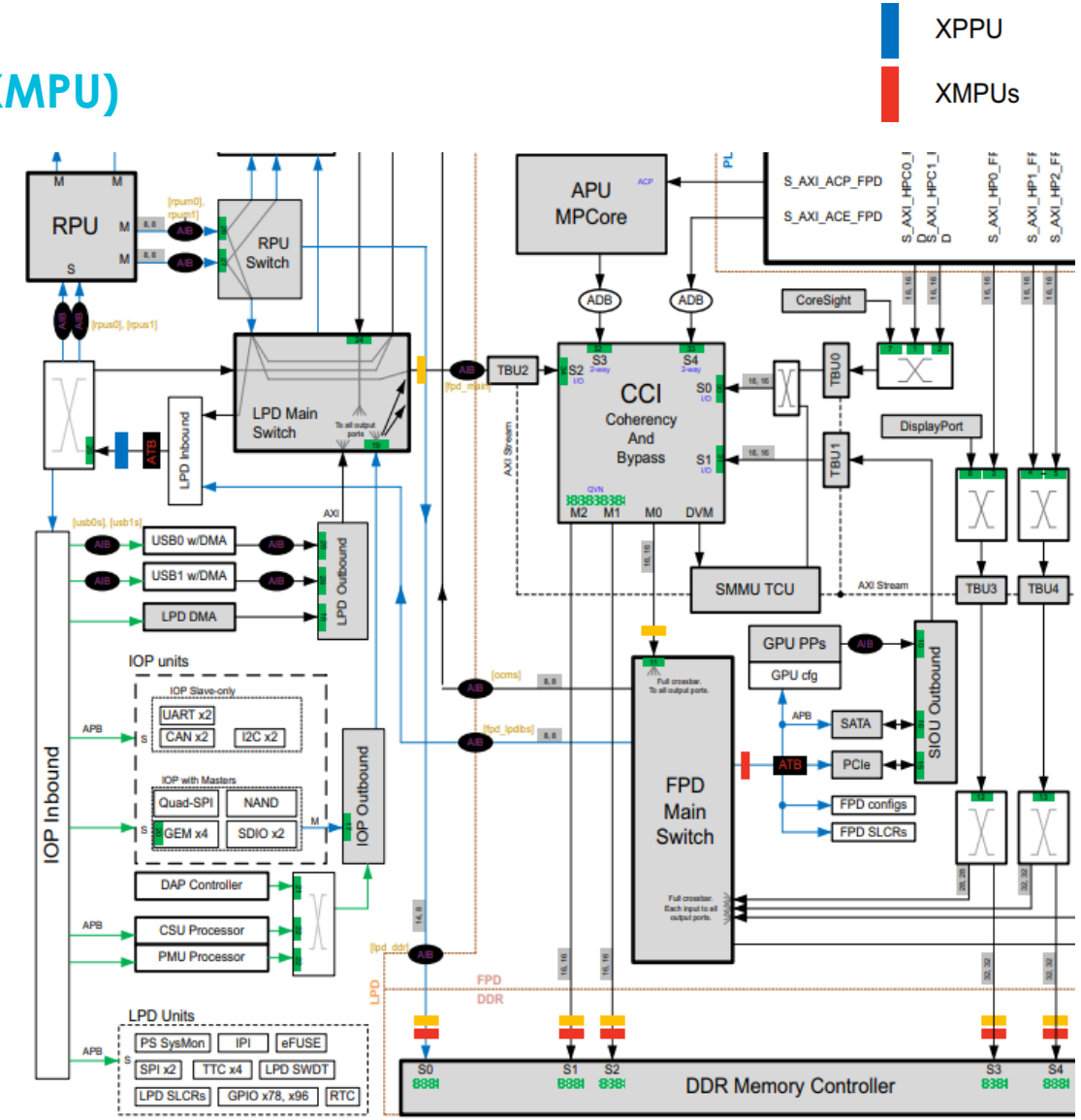
Breaking XPPU/XMPU isolation (CVE-2025-0038)

> Xilinx Peripheral and Memory Protection Units (XPPU/XMPU)

- Provides access control of AXI transactions initiated by bus masters
  - e.g., processors, units, DMA-capable devices
- Restrict their access to slaves
  - e.g., memory, peripherals, IPIs, message buffers

- Support TrustZone's security states

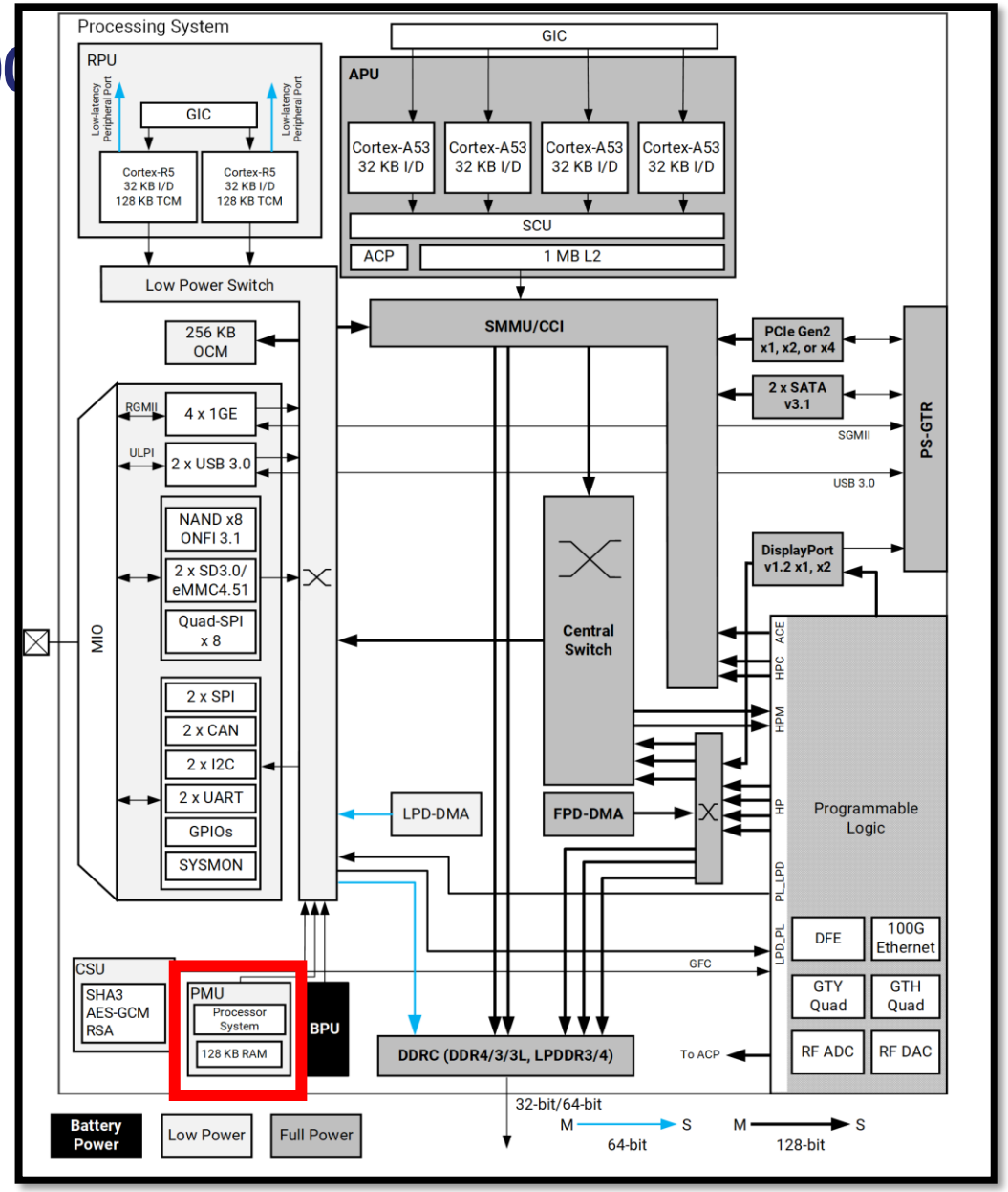
- Enables partitioning user-defined regions of memory and allocate them to specific isolated subsystems (XMPU)
- Enables assigning peripherals to specific isolated subsystems (XPPU)



Breaking XPPU/XMPU isolation (CVE-2025-0

> The Platform Management Unit (PMU)

- MicroBlaze processor that runs in Secure mode
- PMU's tasks:
  - Initialization of the system prior to boot.
  - Power management.
  - System error handling
  - Clock and node management
- Other processors can leverage PMU runtime services through IPIs
- It leverages the CSU (Secure)
  - For crypto accelerators, programmable logic readback, and eFUSE read/write operations



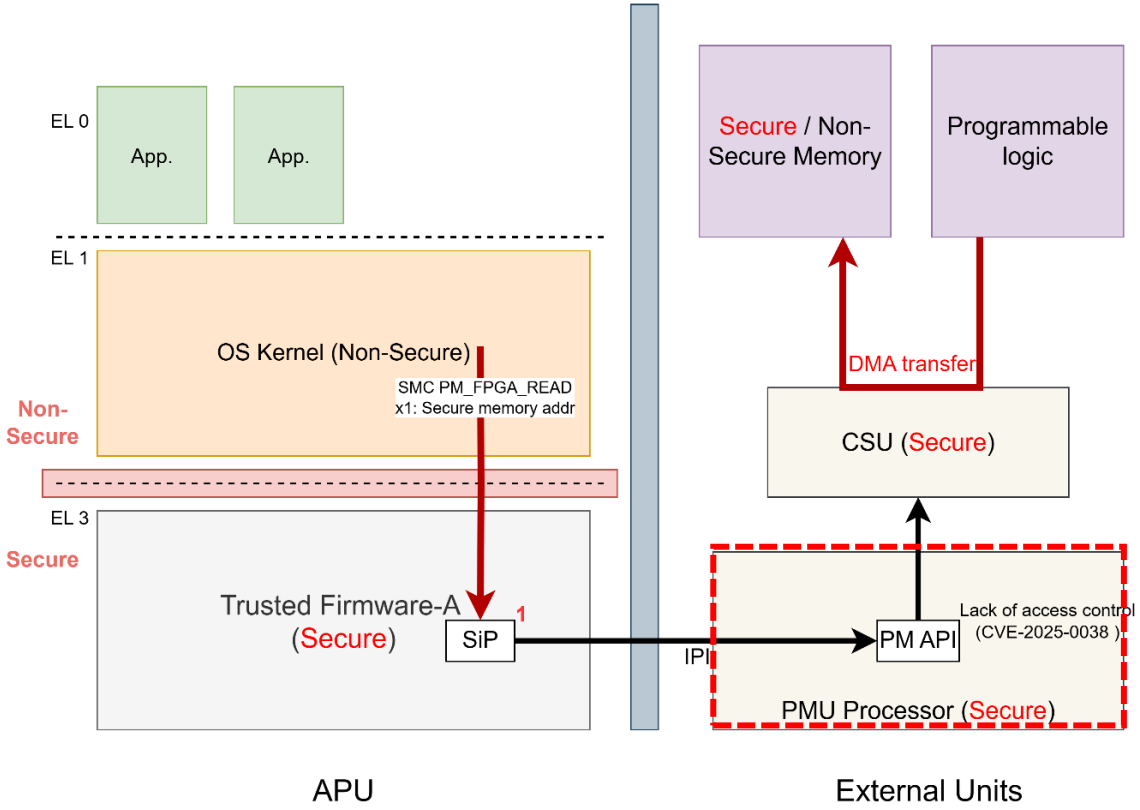
Breaking XPPU/XMPU isolation (CVE-2025-0038)

> At PMU level:

- No check of the processor that requested **PM_FPGA_READ**
  - i.e., no check of the processor (bus-master) that sent the IPI
- No check of the memory pointer passed as an argument

- The master that initiated the request and the master that finally executes it is different
  - **They do not have the same XPPU/XMPU permissions**

- Master who initiates the request: **APU**
- Master who executes the request: **CSU DMA**
  - The XPPU/XMPU could block the transactions of the CSU DMA, but not based on the APU permissions



- PM_FPGA_READ is used for the demonstration, but other services were affected

Breaking XPPU/XMPU isolation (CVE-2025-0038)

> CVE-2025-0038: AMD Zynq UltraScale+ Overwriting Protected Memory Regions Through PMU Firmware

- Description:
  - In AMD Zynq UltraScale+ devices, the lack of address validation when executing CSU runtime services through the PMU Firmware can allow access to isolated or protected memory spaces resulting in the loss of integrity and confidentiality.

- Severity: **6.6 (Medium)**
  - CVSS3.1:AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:H

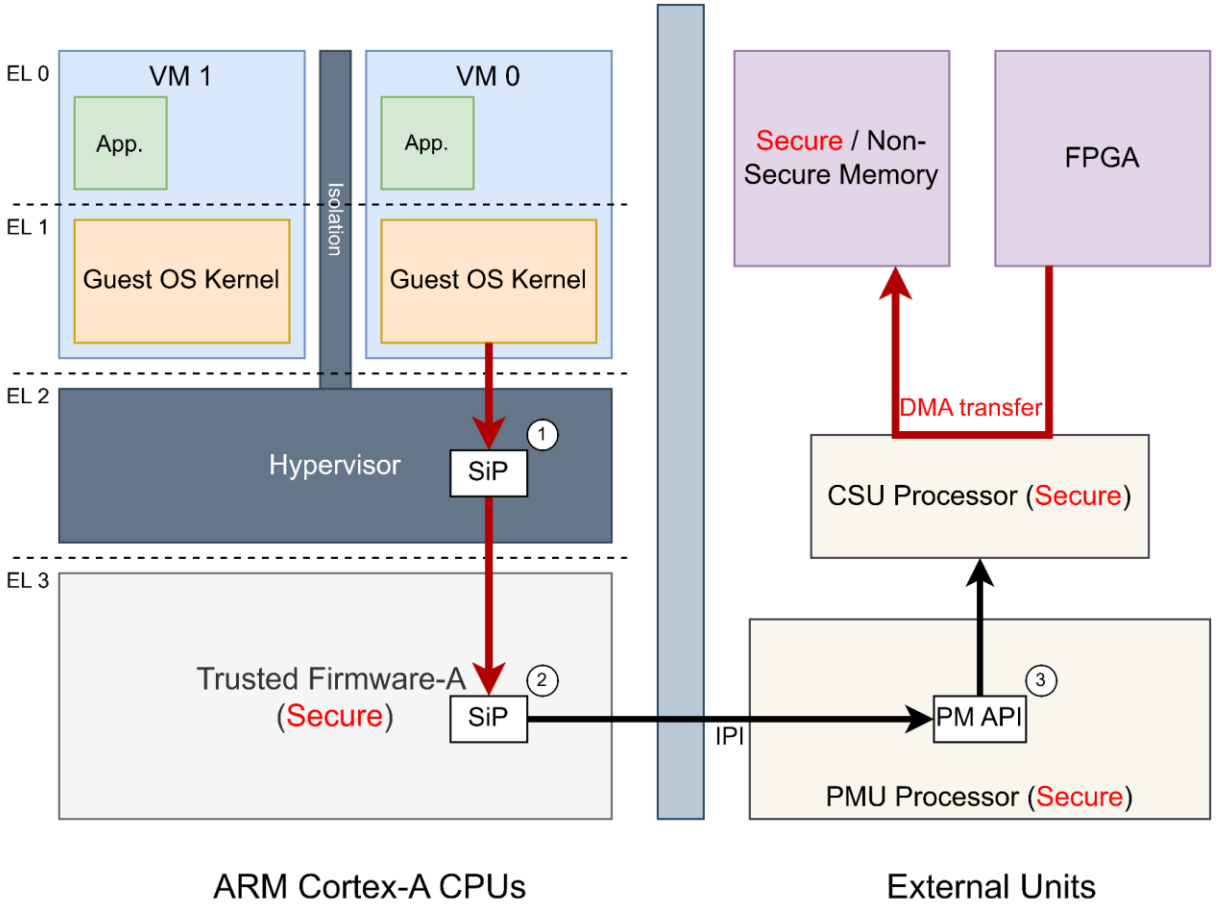
- Affected software:
  - AMD Software Development Kit (SDK), PetaLinux, or Vitis™ Software Platform versions 2017.3 to 2025.1.
- Affected Devices:
  - Kria SOM, Zynq UltraScale+ MPSoCs, Zynq UltraScale+ RFSoCs

- Remediation:
  - Patch of the PMU Firmware to perform memory validation of the memory pointers passed through the IPI messages for commanding the CSU runtime services.

Summary of the vulnerabilities

> **Lack of access control at different levels of granularity**

- At Xen Level (patched)
  - VMs isolation
- At TF-A level (addressed in AMD-SB-8017, CVE-2025-48507)
  - TrustZone isolation
- At PMU level (addressed in AMD-SB-8008, CVE-2025-0038)
  - XPPU and XMPU isolation
  - https://docs.amd.com/r/en-US/000037628/CVE-Details



> **Allows Non-Secure software to leverage functions that are ultimately executed by Secure units**

> **Allows a master to leverage functions that are ultimately performed by another master**

Exploit to gain full access to TrustZone Secure world ?

> How can this security flaw be exploited to gain full access to TrustZone's Secure world ?

- The flaw only allows clearing arbitrary secure/non-secure memory
  - But, it can be leveraged by Non-secure software to gain access to the Secure world
  - Applicable in the default environment provided by AMD SDK, PetaLinux, or Vitis Software Platform versions 2017.3 to 2025.1

- **Attacker:** Non-secure software (e.g., Linux)
  - It can leverage non-secure DMA-capable devices (e.g., USB controller, SD controller)

- **Target:** Secure memory (e.g., Firmware code)

Exploit to gain full access to TrustZone Secure world ?

> IOP DMA-capable peripherals can be switched to Secure or Non-Secure

- E.g., I2C, SPI, SDIO controller

- By default, these peripherals are Non-Secure masters
  - They can only access Non-Secure memory
  - They can be controlled by Non-Secure software

PS Entity	Slave Port	Master Port	Notes
FPD and LPD DMA Units			
DMA channels	SLCR configurable	SLCR configurable	Programmable on a per channel ba
RPU			
RPU R5_0/1	~	SLCR configurable	
RPU TCMs	XPPU configurable	~	External AXI slave port.
LPD Peripherals and Slaves			
Secure SLCR	Secure	~	See Table 10-4.
CSU	Secure	Secure	
PMU	Secure	Secure	
eFUSE/BPD/PS_SYSMON	Secure	~	Fuses, battery power unit, PS SYSM
CoreSight	Secure	Secure	
IOP peripherals	XPPU configurable	SLCR configurable	I2C, GPIO, SPI, GEM Ethernet, SDIO USB, UART, Quad-SPI, and NAND.

- Non-secure software can leverage this vulnerability to gain full access to Secure memory
  - A DMA-capable device controlled by Non-Secure software is switched to Secure mode
  - Then, Non-Secure software can leverage the device to perform a DMA attack on the Secure World

Exploit to gain full access to TrustZone Secure world ?

> IOU_AXI_WPRTCN and IOU_AXI_RPRTCN register

- Belong to IOU_SECURE_SLCR registers
- Define the security states of IOP peripherals
- These registers require secure access
  - **But CSU DMA is Secure…**

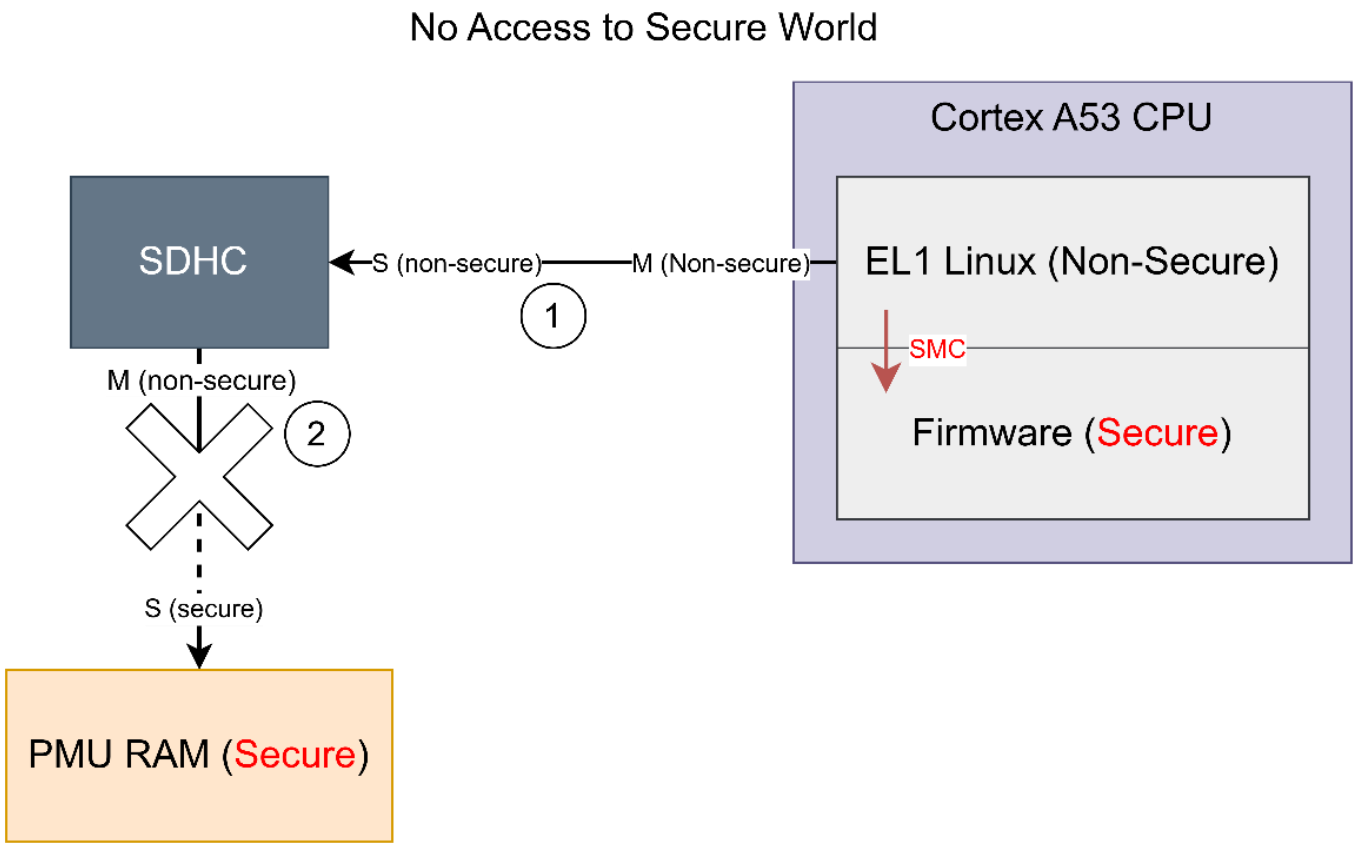
- If IOU_AXI_WPRTCN and IOU_AXI_RPRTCN are cleared
  - These peripherals are switched **to Secure masters**
  - They can then access Secure memory
  - They can still be controlled by Non-Secure software
    - Non-Secure slave interface

PS Entity	Slave Port	Master Port	Notes
FPD and LPD DMA Units			
DMA channels	SLCR configurable	SLCR configurable	Programmable on a per channel ba
RPU			
RPU R5_0/1	~	SLCR configurable	
RPU TCMs	XPPU configurable	~	External AXI slave port.
LPD Peripherals and Slaves			
Secure SLCR	Secure	~	See Table 10-4.
CSU	Secure	Secure	
PMU	Secure	Secure	
eFUSE/BPD/PS_SYSMON	Secure	~	Fuses, battery power unit, PS SYSM
CoreSight	Secure	Secure	
IOP peripherals	XPPU configurable	SLCR configurable	I2C, GPIO, SPI, GEM Ethernet, SDIO USB, UART, Quad-SPI, and NAND.

> Non-Secure Linux can leverage CVE-2025-48507 to clear IOU_AXI_WPRTCN / IOU_AXI_RPRTCN

Exploit to gain full access to TrustZone Secure world ?

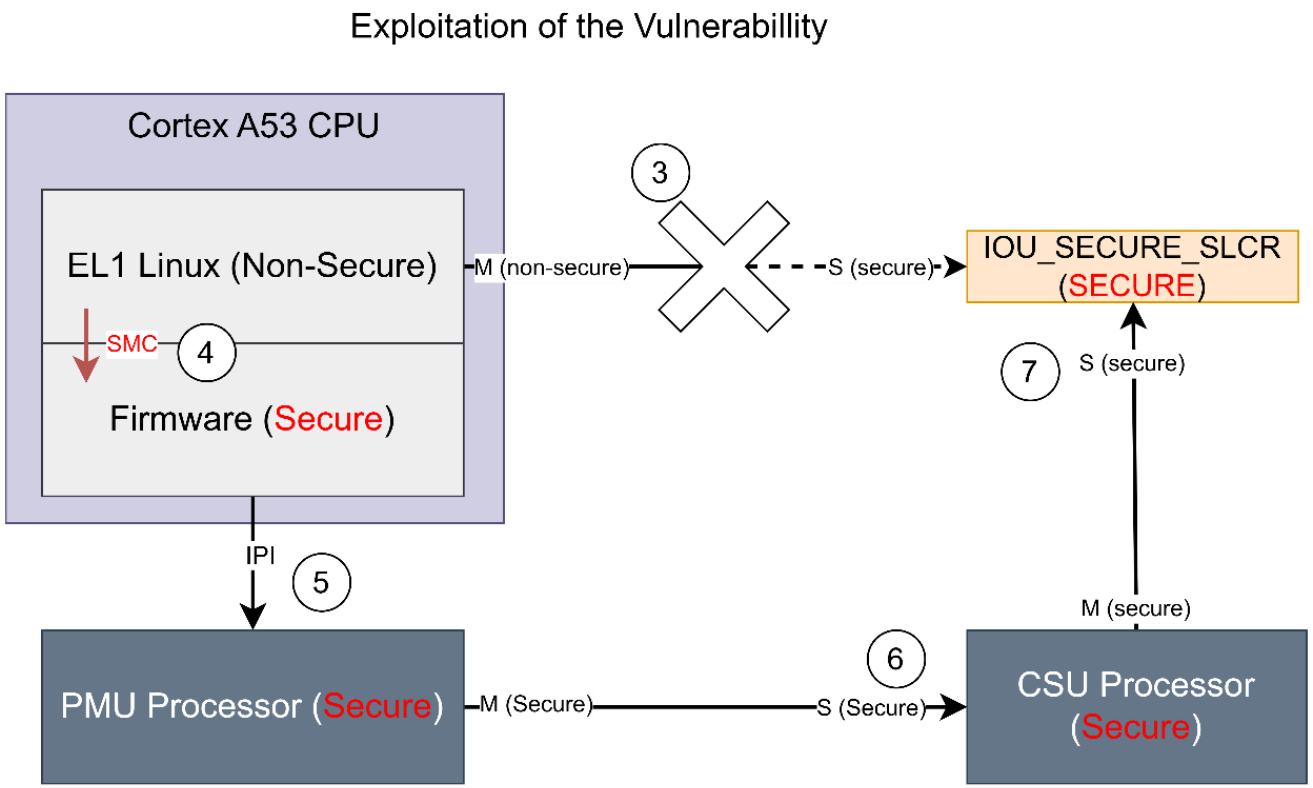
1. Non-Secure Linux leverages the SDHC to read to Secure memory (DMA attack)
2. It fails since the SDHC in Non-secure Master



Exploit to gain full access to TrustZone Secure world ?

3. Non-Secure Linux tries to clear IOU_AXI_WPRTCN to switch the SDHC to Secure Master

- It fails since the IOU_AXI_WPRTCN requires Secure Access and Linux is non-secure

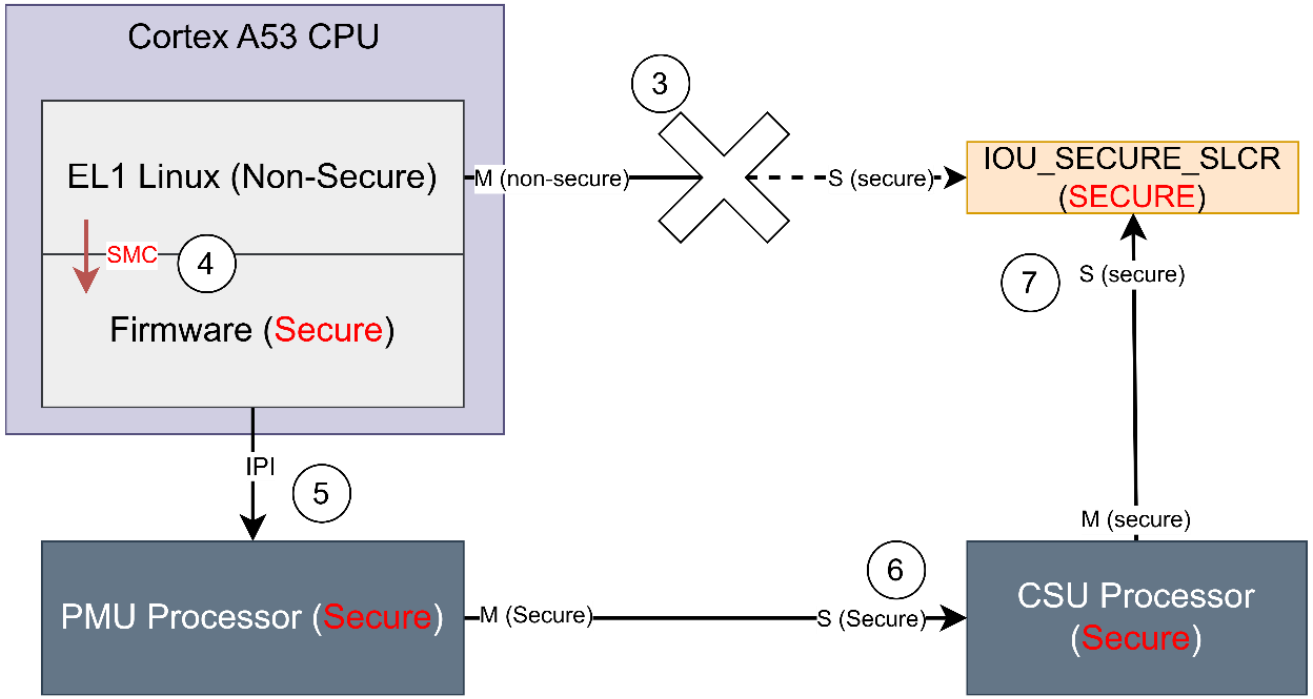


Exploit to gain full access to TrustZone Secure world ?

4. Non-secure Linux leverages CVE-2025-48507 to clear IOU_AXI_WPRTCN / IOU_AXI_RPRTCN

5. 6. The request is handled by the firmware (TF-A), which forwards it to the PMU and then to the CSU processor

Exploitation of the Vulnerabillity

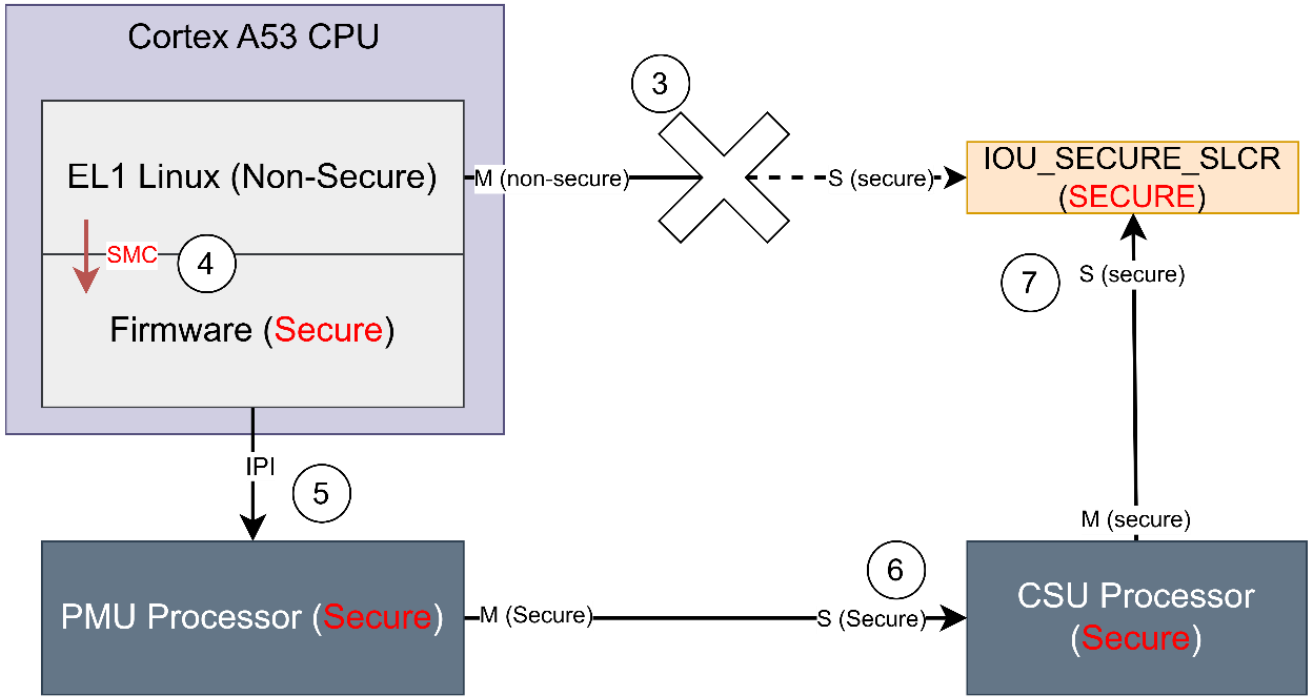


Exploit to gain full access to TrustZone Secure world ?

7. The CSU DMA overwrites the IOU_AXI_WPRTCN and IOU_AXI_RPRTCN registers

- These registers require secure access
- This succeeds as the CSU DMA is also a Secure Master

Exploitation of the Vulnerabillity

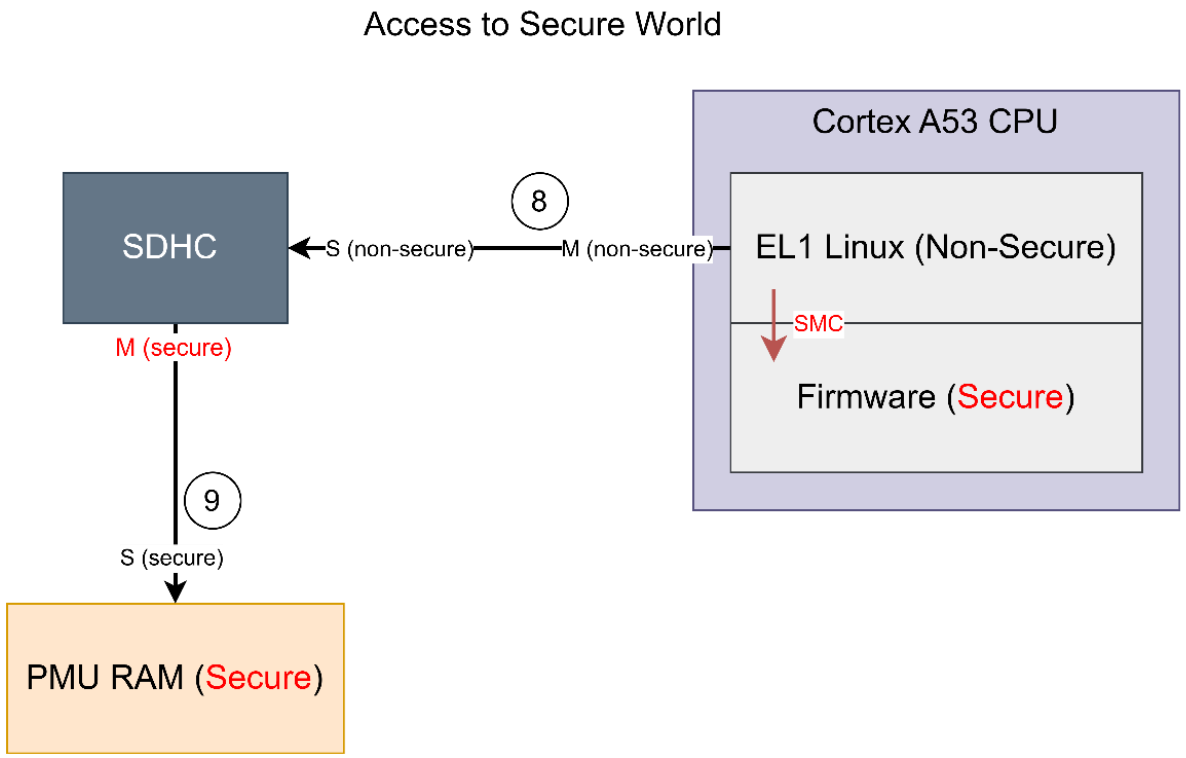


Exploit to gain full access to TrustZone Secure world ?

Now the SDHC is Secure master, it can access secure memory

8. Non-Secure Linux leverages the SDHC to write to Secure memory (DMA attack)

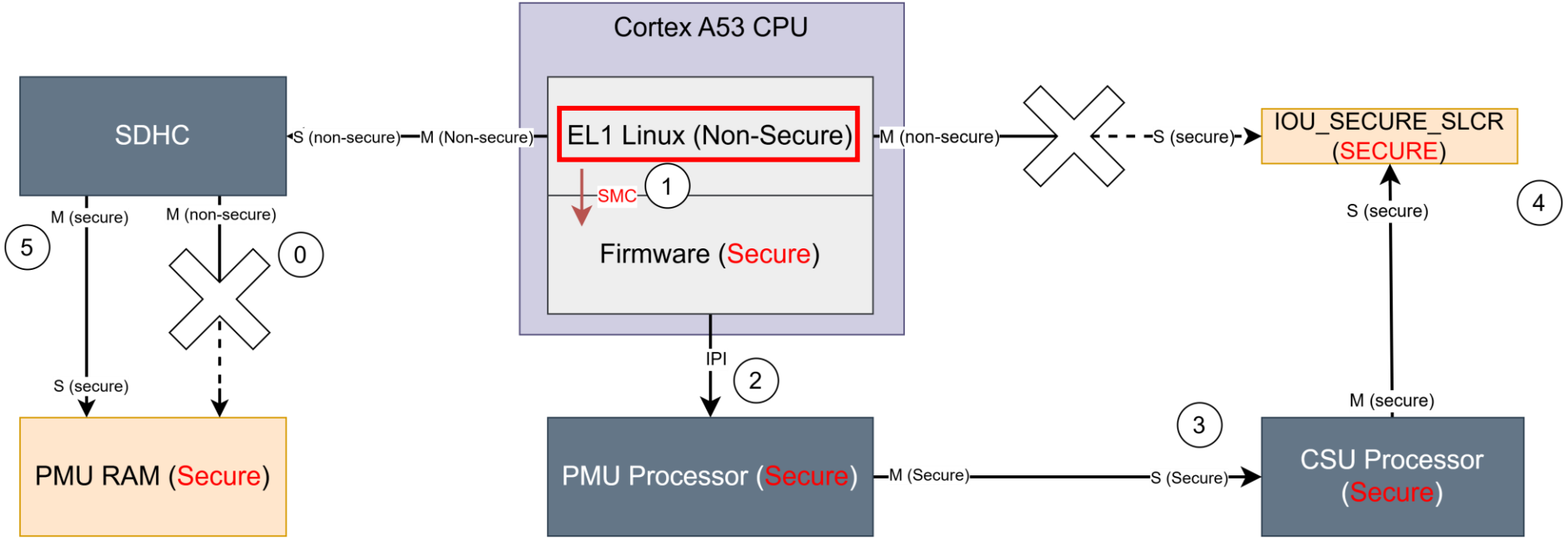
9. It succeeds since the SDHC is now Secure Master



Exploit to gain full access to TrustZone Secure world ?

> Non-Secure Linux leverages CVE-2025-48507 to clear IOU_AXI_WPRTCN / IOU_AXI_RPRTCN

- Then, the SD Host controller is switched to Secure Master
- The SD Host controller slave interface is still Non-Secure
- Non-secure Linux can subsequently carry out a DMA attack to access Secure memory



Conclusion

> On AMD Zynq UltraScale MPSoC, a peripheral can be Non-Secure slave and Secure master…

> It shows the criticality of the SMC interface for breaking isolation at different levels of granularity

- VMs isolation in Xen:
  - Patch: https://github.com/Xilinx/xen/commit/c9de96c0cbe9b2f2aa5e55a0e1e645ca72865102
- TrustZone isolation:
  - CVE-2025-48507:
- XPPU/XMPU isolation
  - CVE-2025-0038: https://docs.amd.com/r/en-US/000037628/CVE-Details

> Services accessed through the SMC interface must be validated in software to ensure it does not break the isolation provided by the hardware